



Weekly IT Security Brief (Official-source-first) | 2026-09-20 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2025-39964(2026-09-21), CVE-2026-53266(2026-09-21), CVE-2025-39682(2026-09-21). Prioritize internet-facing and privileged systems first.
- Threat trend #1: From guidance to action: Security fundamentals that materially reduce risk. AI has made fundamental changes to the operating environment for cybersecurity. Explore exposure management guidance on recommended controls and take action and stay...
- Threat trend #2: Improving email security outcomes with real-world Microsoft Defender insights. The latest email security benchmarking reports show strong Microsoft Defender performance across pre-delivery and post-delivery scenarios and reveal where threats...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2025-39964

CVE Title	CVE-2025-39964 linux/linux_kernel Unknown Type
CVE Description	In the Linux kernel, the following vulnerability has been resolved:
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	linux/linux_kernel, siemens/simatic_s7-1500_cpu_1518-4_pn\dp_mfp_firmware, siemens/simatic_s7-1500_cpu_1518-4_pn\dp_mfp, siemens/simatic_s7-1500_cpu_1518f-4_pn\dp_mfp_firmware, siemens/simatic_s7-1500_cpu_1518f-4_pn\dp_mfp
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-21
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-39964

CVE-2026-53266

CVE Title	CVE-2026-53266 linux/linux_kernel Unknown Type
CVE Description	In the Linux kernel, the following vulnerability has been resolved:
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	linux/linux_kernel
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-21
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-53266

CVE-2025-39682

CVE Title	CVE-2025-39682 linux/linux_kernel Unknown Type
CVE Description	In the Linux kernel, the following vulnerability has been resolved:
Note	only contiguous DATA records (any number of them)
Note	one non-DATA record
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	linux/linux_kernel, debian/debian_linux
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-21
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-39682

CVE-2026-58704

CVE Title	CVE-2026-58704 google/android Unknown Type
CVE Description	In Cellular Modem, there is a possible permission bypass due to a logic error in the code. This could lead to remote (proximal/adjacent) escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	google/android
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-58704

CVE-2026-76460

CVE Title	CVE-2026-76460 cisco/identity_services_engine Unknown Type
CVE Description	A vulnerability in an API of Cisco Identity Services Engine (ISE) could allow an unauthenticated, remote attacker to bypass authentication.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	cisco/identity_services_engine, cisco/identity_services_engine_passive_identity_connector
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-76460

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-90485

CVE Title	CVE-2026-90485 待核實 Unknown Type
CVE Description	A flaw has been found in IOBit Uninstaller 15.5.0.11. Affected by this issue is the function sub_11838 of the file IRegistryFilter.sys of the component IOCTL Dispatch Handler. This manipulation causes null pointer dereference. The attack requires local access. The exploit has been published and may be used. Identical IRegistryFilter.sys ships across multiple IObit families. The vendor was contacted early about thi...
Affected Products	待核實
Risk Score	5.5 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-90485

CVE-2026-79300

CVE Title	CVE-2026-79300 待核實 Unknown Type
CVE Description	SEP sesam before 5.2.0.24 mishandles User Authorization with MFA. If AD authentication is configured and MFA is enforced, an attacker can create a second OTP access capability. SEP sesam and Active Directory handle username capitalization differently, which may allow multiple SEP sesam user accounts to be created for the same Active Directory (AD) account. Active Directory treats usernames as case-insensitive, while...
Affected Products	待核實
Risk Score	3.5 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-79300

CVE-2026-90486

CVE Title	CVE-2026-90486 待核實 SSRF
CVE Description	A vulnerability has been found in openstatusHQ openstatus up to f04c827112f30a11d571ebdad3892826034d6265. Affected by this vulnerability is an unknown functionality of the file apps/status-page/src/lib/proxy/resolve-custom-domain-rewrite.ts. The manipulation leads to server-side request forgery. The attack may be initiated remotely. This product uses a rolling release model to deliver continuous updates. As a result...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-90486

CVE-2026-90487

CVE Title	CVE-2026-90487 待核實 Unknown Type
CVE Description	A vulnerability was found in Xuxueli xxl-job up to 3.4.2. Affected by this issue is some unknown functionality of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobGroupController.java. The manipulation results in improper privilege management. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-90487



Report B: Threat Intelligence News (last 7 days)

Headline: From guidance to action: Security fundamentals that materially reduce risk

Source	Microsoft Security Blog
Published	Thu, 17 Sep 2026 17:00:00 +0000
Key Takeaway	AI has made fundamental changes to the operating environment for cybersecurity. Explore exposure management guidance on recommended controls and take action and stay ahead of cyberthreats. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/17/from-guidance-to-action-security-fundamentals-that-materially-reduce-risk/

Headline: Improving email security outcomes with real-world Microsoft Defender insights

Source	Microsoft Security Blog
Published	Thu, 17 Sep 2026 16:00:00 +0000
Key Takeaway	The latest email security benchmarking reports show strong Microsoft Defender performance across pre-delivery and post-delivery scenarios and reveal where threats and defenses continue to evolve. The post Improving email security outcomes with real-world Microsoft Defender insights appeared first on Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/17/improving-email-security-outcomes-with-real-world-microsoft-defender-insights/

Headline: CISA Hosts Cyber Storm X, Nationwide Cybersecurity Exercise to Strengthen Resilience

Source	CISA News
Published	Fri, 18 Sep 26 12:00:00 +0000
Key Takeaway	CISA Hosts Cyber Storm X, Nationwide Cybersecurity Exercise to Strengthen Resilience Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-hosts-cyber-storm-x-nationwide-cybersecurity-exercise-strengthen-resilience

Headline: New CISA Guidance Helps Critical Infrastructure Detect, Observe and Impede Malicious Cyber Activity

Source	CISA News
Published	Wed, 16 Sep 26 12:00:00 +0000
Key Takeaway	New CISA Guidance Helps Critical Infrastructure Detect, Observe and Impede Malicious Cyber Activity Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/new-cisa-guidance-helps-critical-infrastructure-detect-observe-and-impede-malicious-cyber-activity

Headline: Should you care about an “AI slowdown?”

Source	Cisco Talos Blog
Published	Thu, 17 Sep 2026 18:00:23 GMT
Key Takeaway	In this week's Threat Source, David talks about why focusing on your security basics is still your best bet, even in a world with rapid AI advancements. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ics/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/should-you-care-about-an-ai-slowdown/

Headline: Ransomware incidents in Japan in the first half of 2026: Investigation of The Gentlemen’s infrastructure and evidence of Qilin's AI use

Source	Cisco Talos Blog
Published	Thu, 17 Sep 2026 10:00:43 GMT
Key Takeaway	Ransomware incidents in Japan rose 4.7% year over year. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	待核實/japan
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/ransomware-incidents-in-japan-in-the-first-half-of-2026/

Headline: Claude Opus 5 Helped Researchers Take Over OpenAI Staff Accounts via Chained Flaws

Source	The Hacker News
Published	Sun, 20 Sep 2026 00:06:53 +0530
Key Takeaway	Three researchers at the security firm Hacktron used Anthropic's Claude Opus 5 to chain two flaws and take over the ChatGPT and Codex accounts of several OpenAI employees, then reach an internal OpenAI code repository. The chain began with a bug in the software that runs OpenAI's public help forum a Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/l...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/09/claude-opus-5-helped-researchers-take.html

Headline: Can You Prove a New CVE Is Exploitable Before Attackers Do? Learn How in This Webinar

Source The Hacker News

Published Sat, 19 Sep 2026 18:58:48 +0530

Key Takeaway But that still does not answer the question that matters: Can it actually be exploited in your environment? Mythos-class AI is compressing the time between disclosure and working exploitation, while many security programs still validate risk on weekly or quarterly cycles.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://thehackernews.com/2026/09/can-you-prove-new-cve-is-exploitable.html>

Headline: TigerByte Cyber Emerges From Stealth With \$3 Million in Funding

Source	SecurityWeek
Published	Sat, 19 Sep 2026 14:30:00 +0000
Key Takeaway	The company has secured over \$7 million in contracts with US government agencies, including the US Space Force, the US Navy, and DARPA. The post TigerByte Cyber Emerges From Stealth With \$3 Million in Funding appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/tigerbyte-cyber-emerges-from-stealth-with-3-million-in-funding/

Headline: In Other News: Ransomware Developer Sentenced, Plugin4Shell AI Attack, Critical SAP Flaw

Source	SecurityWeek
Published	Fri, 18 Sep 2026 14:25:00 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: Mandiant's 2026 AI risk report, PhantomRaven malware used by bug bounty hunter, WordPress plugin bug exploited. The post In Other News: Ransomware Developer Sentenced, Plugin4Shell AI Attack, Critical SAP Flaw appeared first on SecurityWeek Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/laterna...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-ransomware-developer-sentenced-plugin4shell-ai-attack-critical-sap-flaw/

Headline: BragJack attacks hijack AI browser agents through malicious extensions

Source	BleepingComputer
Published	Sat, 19 Sep 2026 10:56:31 -0400
Key Takeaway	BragJack, a proof-of-concept attack from Forever Security's Gal Weizman, hijacks the AI assistants in Chrome, Edge, Opera Neon, Perplexity Comet, and Claude in Chrome using one malicious extension. The Prompt Forcing technique earned over \$20,000 in bounties and two CVEs. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/bragjack-attacks-hijack-ai-browser-agents-through-malicious-extensions/

Headline: North Korean WaterPlum hackers infected 30,000 devices worldwide

Source BleepingComputer

Published Sat, 19 Sep 2026 10:05:15 -0400

Key Takeaway A joint law enforcement advisory warns that the North Korean hacking group WaterPlum compromised at least 30,000 devices worldwide from December 2025 through July 2026 and transferred more than \$10.7 million in stolen cryptocurrency to North Korea. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target cryptocurrency/worldwide

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/north-korean-waterplum-hackers-infected-30-000-devices-worldwide/>



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)